HACKING MACCHINA VIRTUALE: MR ROBOT

OBIETTIVO

Riuscire a portare a termine una sessione di hacking trovando le 3 chiavi nascoste.

AMBIENTE DI LAVORO

Il laboratorio è stato svolto in ambiente isolato su VirtualBox collegando tramite Pfsense la macchina attaccante (Kali) e la macchina target (Mr Robot)

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.50.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-15 11:29 -0400
Nmap scan report for 192.168.50.1
Host is up (0.00099s latency).
MAC Address: 08:00:27:21:58:21 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.50.11
Host is up (0.0013s latency).
MAC Address: 08:00:27:03:2F:DD (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.50.10
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 7.01 seconds
```

FASE DI ATTACCO

1. Prima di tutto ho eseguiro una scansione in nmap per determinare le porte e la versione dei servizi attvi

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV 192.168.50.11 -T4
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-15 11:30 -0400
Nmap scan report for 192.168.50.11
Host is up (0.0019s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
443/tcp open   ssl/http Apache httpd
MAC Address: 08:00:27:03:2F:DD (Oracle VirtualBox virtual NIC)

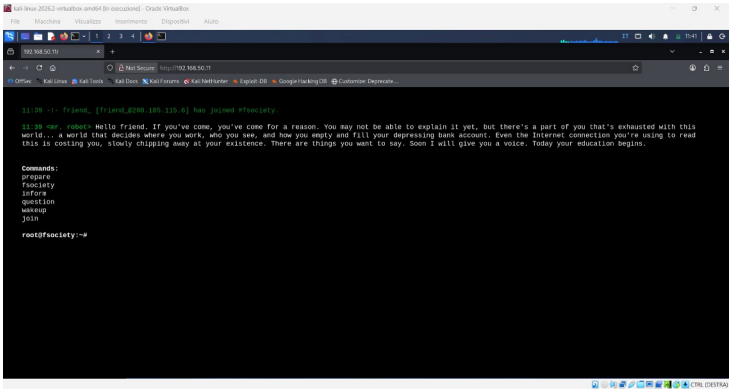
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.64 seconds
```

Ho individuato 2 servizi attivi alle porte 80/tcp e 443/tcp e una porta chiusa 22/tcp.

VETTORE DI ATTACCO: PORTA 80

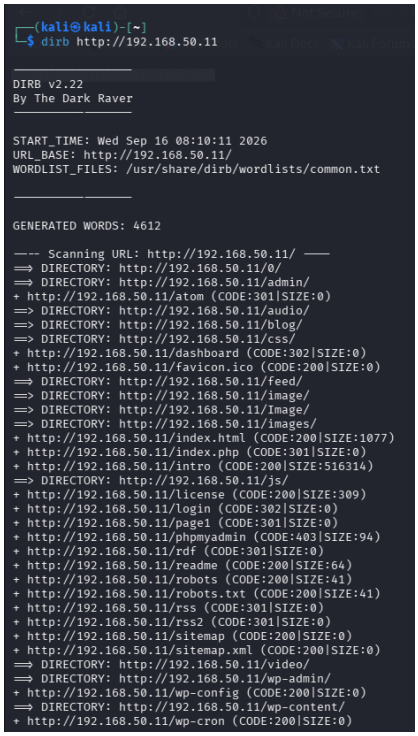
FLAG 1

1. Ho fatto accesso alla pagina web della macchina e ho trovato una scheda che mi invita ad usare vari comandi.

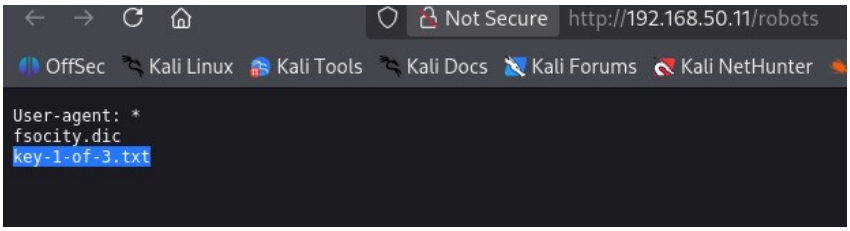


Impostando quella serie di comandi vengono dati una serie di informazioni riguardanti un’organizzazione che vuole reclutare l’utente per le sue abilità di hacker.

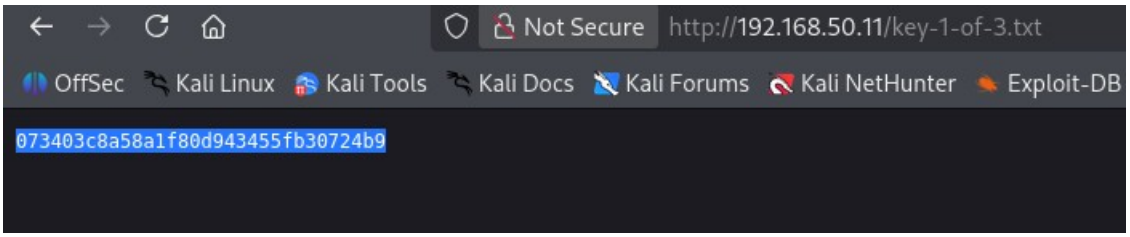
2. Ho poi eseguito l’enumerazione del sito per individuare cartelle e file nascosti tramite Dirb.



3. Ho individuato la pagina robot.txt che solitamente nasconde materiale interessante.



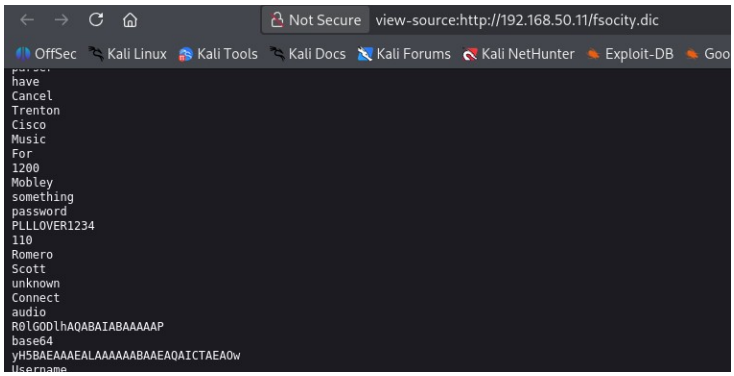
4. Ho inserito key-1-of-3.txt nell’URL e ho trovato una cartella contenente un codice.



L’analisi di questa stringa ha portato alla conclusione che si tratta di un hash in MD5, ma che dopo vari tentativi con John the ripper risulta non decodificabile perché si tratta della flag1→073403c8a58a1f80d943455fb30724b9.

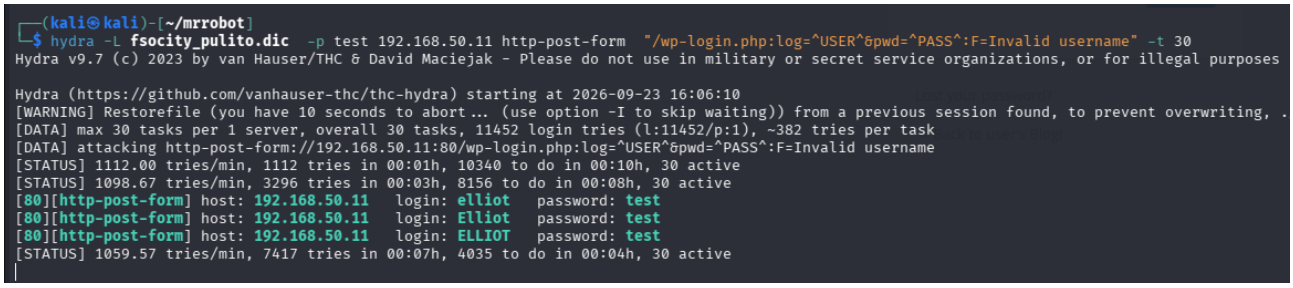
FLAG 2

1. Ho testato anche il file fsocity.dic e ho trovata una pagina piena di stringhe.



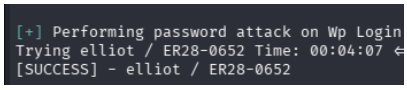
Potrebbe essere un dizionario per attacchi Brute Force. Ho scaricato il file tramite comando wget e poi ho ordinato e filtrato i doppioni che ho inserito nel file fsocity_pulito.dic.

2. Tra le pagine enumerate è presente un blog su Wordpress dove è possibile fare login. Grazie ad Hydra si può trovare l'username sfruttando il fatto che quando viene scritto l'username giusto la pagina restituisce che la password è sbagliata per l'utente inserito. Ho usato come dizionario il file ricavato precedentemente

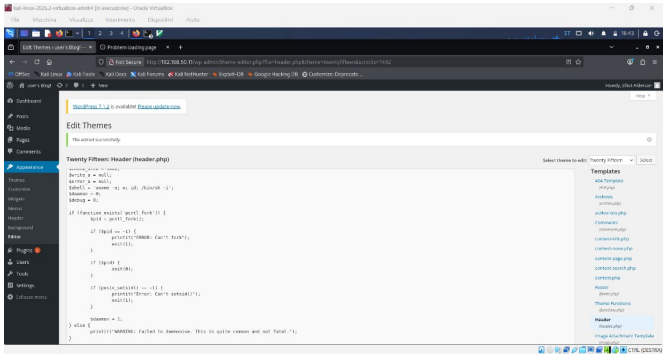


3. Grazie agli username trovati si puo ricavare la password usando lo stesso dizionario. Questa volta ho usato Wpscan che ha trovato la password ER28-0652.

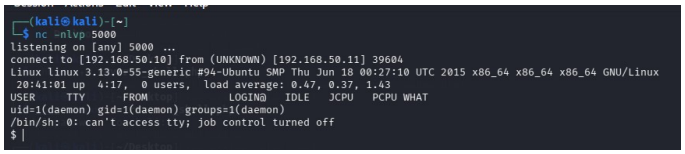




4 Dopo aver avuto accesso sono andata alla pagina Appereances→ editor dove ho potuto inserire lo script della reverse shell nell'header.



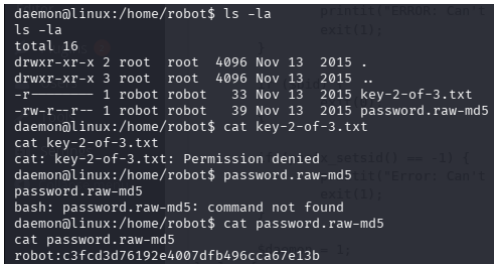
Tramite nc ho messo in ascolto Kali per ricevere la shell del server.



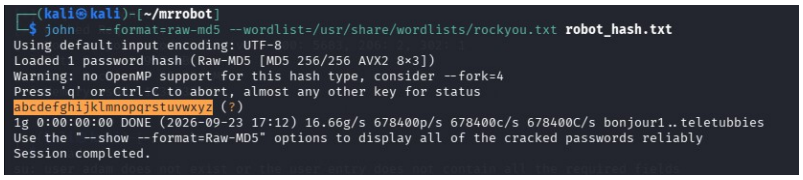
5. Ho reso stabile la shell.



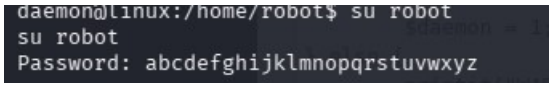
6. Accedendo al percorso /home/robot ho trovato due file: uno contenente la seconda flag, ma per ora inacessibile, e un altro contenente un hash md5, probabilmente la password dell'utente robot.



7. Da terminale ho sfruttato John the ripper per trovare a quale password corrisponde l'hash (abcdefghijklmnopqrstuvwxyz).



Grazie alla password ho fatto il passaggio all'utente robot.

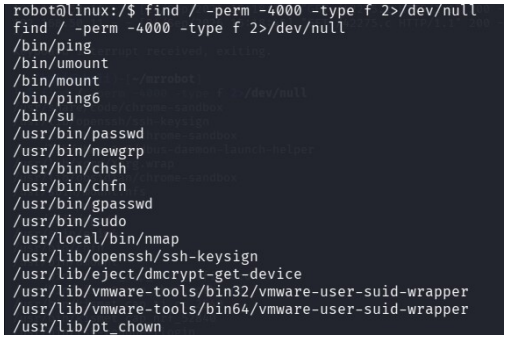


8. L'utente robot ha i permessi di lettura al file della seconda flag → 822c73956184f694993bede3eb39f959 .



FLAG 3

1. Per trovare la terza flag ho cercato i file che avessero i SUID attivati.



2. Tramite Nmap ho ottenuto una shell con privilegi root.



3. Dopo aver eseguito l’escalation di privilegi ho avuto accesso alla cartella root, dove ho trovato l’ultima flag → 04787ddef27c3dee1ee161b21670b4e4.

